VULNERA

Gestão de análises de segurança

Relatório DAST

http://host.docker.internal:18173/

EMPRESA

host.docker.internal

APLICAÇÃO

Spider + análise passiva — OWASP ZAP

GERADO EM

09/10/2026 às 10:01

Descoberta de URLs pelo spider tradicional e análise passiva das respostas HTTP. Solicitado por Vulnera Admin · Duração: 26s.

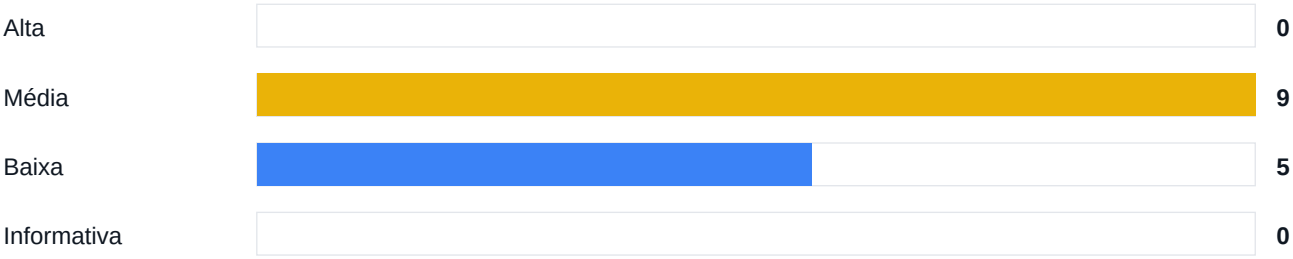
Documento confidencial — uso restrito às partes envolvidas na análise.

Sumário executivo

O scan contra http://host.docker.internal:18173/ identificou 14 alertas. Cada um está detalhado, por ordem de severidade, na seção seguinte deste documento.

14	0	9	5
Total de achados	Alto	Médio	Baixo

Distribuição por risco



Findings por severidade

Média 1. Missing Anti-clickjacking Header

Confiança: Medium · CWE-1021 · WASC-15

URL
http://host.docker.internal:18173/deep/a

PARÂMETRO
x-frame-options

DESCRIÇÃO
The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

SOLUÇÃO
Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Média 2. Missing Anti-clickjacking Header

Confiança: Medium · CWE-1021 · WASC-15

URL
http://host.docker.internal:18173/page

PARÂMETRO
x-frame-options

DESCRIÇÃO
The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

SOLUÇÃO
Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Média 3. Missing Anti-clickjacking Header

Confiança: Medium · CWE-1021 · WASC-15

URL
http://host.docker.internal:18173/iframe-only

PARÂMETRO
x-frame-options

DESCRIÇÃO
The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

SOLUÇÃO
Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Média 4. Content Security Policy (CSP) Header Not Set

Confiança: High · CWE-693 · WASC-15

URL
http://host.docker.internal:18173/

DESCRIÇÃO

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

SOLUÇÃO

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Média 5. Missing Anti-clickjacking Header

Confiança: Medium · CWE-1021 · WASC-15

URL

http://host.docker.internal:18173/

PARÂMETRO

x-frame-options

DESCRIÇÃO

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

SOLUÇÃO

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Média 6. Absence of Anti-CSRF Tokens

Confiança: Low · CWE-352 · WASC-9

URL

http://host.docker.internal:18173/

DESCRIÇÃO

No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session riding, confused deputy, and sea surf. CSRF attacks are effective in a number of situations, including: * The victim has an active session on the target site. * The victim is authenticated via HTTP auth on the target site. * The victim is on the same local network as the target site. CSRF has primarily been used to perform an action against a target site using

the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy.

SOLUÇÃO

Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.

EVIDÊNCIA

<form method="POST" action="/submit">

Média 7. Content Security Policy (CSP) Header Not Set

Confiança: High · CWE-693 · WASC-15

URL

http://host.docker.internal:18173/deep/a

DESCRIÇÃO

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

SOLUÇÃO

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Média 8. Content Security Policy (CSP) Header Not Set

Confiança: High · CWE-693 · WASC-15

URL

http://host.docker.internal:18173/iframe-only

DESCRIÇÃO
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

SOLUÇÃO
Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Média 9. Content Security Policy (CSP) Header Not Set

Confiança: High · CWE-693 · WASC-15

URL
http://host.docker.internal:18173/page

DESCRIÇÃO
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

SOLUÇÃO
Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Baixa 10. X-Content-Type-Options Header Missing

Confiança: Medium · CWE-693 · WASC-15

URL
http://host.docker.internal:18173/robots.txt

PARÂMETRO
x-content-type-options

DESCRIÇÃO
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

SOLUÇÃO
Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by

the web application/web server to not perform MIME-sniffing.

Baixa 11. X-Content-Type-Options Header Missing

Confiança: Medium · CWE-693 · WASC-15

URL
http://host.docker.internal:18173/iframe-only

PARÂMETRO
x-content-type-options

DESCRIÇÃO
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

SOLUÇÃO
Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

Baixa 12. X-Content-Type-Options Header Missing

Confiança: Medium · CWE-693 · WASC-15

URL
http://host.docker.internal:18173/sitemap.xml

PARÂMETRO
x-content-type-options

DESCRIÇÃO
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

SOLUÇÃO
Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

Baixa 13. X-Content-Type-Options Header Missing

Confiança: Medium · CWE-693 · WASC-15

URL
http://host.docker.internal:18173/page

PARÂMETRO
x-content-type-options

DESCRIÇÃO
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

SOLUÇÃO
Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

Baixa 14. X-Content-Type-Options Header Missing

Confiança: Medium · CWE-693 · WASC-15

URL
http://host.docker.internal:18173/

PARÂMETRO
x-content-type-options

DESCRIÇÃO
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

SOLUÇÃO
Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

Apêndice

METODOLOGIA

O spider tradicional do OWASP ZAP descobre URLs e recursos na origem e subárvore do alvo, com limites de duração, profundidade e quantidade de filhos por nó. As respostas recebidas durante o rastreamento são analisadas pelas regras passivas do ZAP. O processamento e envio de formulários estão desativados, assim como os testes ativos de exploração. Os achados são normalizados e persistidos com fingerprint estável, para reconhecer o mesmo achado entre execuções.

VERSÃO DO ZAP

Consulte o relatório HTML original do ZAP (botão "Ver relatório do ZAP" na tela do scan), que traz a versão usada nesta execução no próprio cabeçalho.

ESCOPO

Alvo: http://host.docker.internal:18173/. O rastreamento fica restrito à origem e subárvore informadas, excluindo URLs com query, credenciais ou caminhos sensíveis.

DESCOBERTA REGISTRADA

9 URLs no escopo. Limites desta execução: 1 min, profundidade 2, 30 filhos por nó e 1 thread. A contagem inclui recursos e não comprova cobertura completa da aplicação.

TRIAGEM E GESTÃO DE RESULTADOS

O pentester pode registrar a triagem e promover manualmente um achado para vulnerabilidade de um projeto, revisando o vetor CVSS sugerido antes de salvar. A vulnerabilidade entra no fluxo de gestão e remediação do Vulnera. A comparação entre execuções reais do mesmo alvo apresenta achados novos, resolvidos e que continuam abertos.

LIMITAÇÕES CONHECIDAS

O ZAP não fornece vetor CVSS: o risco do alerta não substitui a avaliação humana. No perfil atual, o spider tradicional não executa JavaScript, portanto rotas de uma SPA que dependem dessa execução podem não ser descobertas. O perfil atual não cobre exploração ativa, envio de formulários ou uma auditoria completa da aplicação. Não há agendamento recorrente nem varredura de múltiplos alvos num único scan.